

CIS Arista EOS benchmark

v1.0.0 - 08-03-2026

Terms of Use

Please see the below link for our current terms of use:

<https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/>

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is **NEVER** acceptable to host a CIS Benchmark in **ANY** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use	1
Table of Contents	2
Overview	4
Important Usage Information	4
Key Stakeholders	4
Apply the Correct Version of a Benchmark	5
Exceptions	5
Remediation	6
Summary	6
Target Technology Details	7
Intended Audience.....	7
Consensus Guidance	8
Typographical Conventions.....	9
Recommendation Definitions.....	10
Title.....	10
Assessment Status.....	10
Automated	10
Manual.....	10
Profile	10
Description.....	10
Rationale Statement	10
Impact Statement.....	11
Audit Procedure.....	11
Remediation Procedure.....	11
Default Value.....	11
References	11
CIS Critical Security Controls® (CIS Controls®)	11
Additional Information.....	11
Profile Definitions	12
Acknowledgements	13
Recommendations	14
1 EOS Services	14
1.1 Control Plane.....	14
1.1.1 Control Plane Traffic	15
1.1.1.1 Ensure the Management VRF Exists (Manual)	16
1.1.2 Control Plane ACL (Manual).....	17

1.1.3 Control Plane Policy Map (Manual)	20
1.1.4 Network Time Protocol (Manual)	24
1.1.5 NTP authentication (Manual)	25
1.1.6 DNS Configuration (Manual).....	26
1.1.7 Logging (Manual).....	27
1.1.8 VLAN Management (Manual)	28
1.1.9 Syslog with TLS support (Manual).....	29
1.2 Enable AES-GCM Encryption of EOS Secrets (Manual).....	31
2 Device Access	32
2.1 Password Management	33
2.1.1 Do not allow remote login without a password (Manual)	34
2.1.2 Configure an enable password (Manual).....	35
2.1.3 Create a password complexity policy (Manual)	36
2.1.4 Verify root login is disabled (Manual)	38
2.3 User Role Management	39
2.3.1 Roles (Manual).....	40
2.4 Console Access	42
2.4.1 Idle Timeout (Manual).....	43
2.4.2 Emergency Console Access (Manual)	44
2.5 TACACS+/RADIUS	45
2.5.1 Configure TACACS+/RADIUS server (Manual)	46
2.5.2 Server Groups (Manual)	47
2.5.3 Authentication, Authorization, and Accounting (Manual).....	48
2.6 SSH Access	50
2.6.1 Limit SSH Access Only To The Network Management Segment (Manual)	51
2.6.2 Set Idle Timeout for SSH to 10 Minutes or Less (Manual).....	52
2.6.3 Remove cryptographically weak algorithms (Manual)	53
2.7 SNMP	54
2.7.1 Limit SNMP Access To Management VRF (Manual)	55
2.7.2 Ensure SNMP Community (Manual).....	56
2.7.3 Use SNMPv3 Instead of Earlier Versions (Manual).....	57
2.9 Login Banner	58
2.9.1 Login Banner (Manual)	59
2.8 Telnet access (Manual)	61
2.9 API access using https (Manual)	62
3 Routing Protocols.....	63
3.1 IGP Authentication.....	64
3.1.1 OSPF Interface Authentication (Manual)	65
3.1.2 ISIS Interface and Instance Authentication (Manual)	67
3.2 BGP Authentication	68
3.2.1 BGP Authentication (Manual)	69
3.2.2 BGP TCP Authentication Option (TCP-AO) (Manual)	70
Appendix: Summary Table	72
Appendix: Change History	75

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the [CIS Website](#). They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- [CIS Configuration Assessment Tool \(CIS-CAT® Pro Assessor\)](#)
- [CIS Benchmarks™ Certified 3rd Party Tooling](#)

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that **ALL** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.
- **Use the most recent version of a Benchmark:** This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed [Build Kits](#) for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
 - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
 - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
 - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
 - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
 - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the [CIS Website](#). All other formats of the CIS Benchmarks™ (MS Word, Excel, and [Build Kits](#)) are available for CIS [SecureSuite](#)® members.

CIS-CAT® Pro is also available to CIS [SecureSuite](#)® members.

Target Technology Details

This guide is provided as a template to securing Arista devices running Arista EOS.

This guide was tested against Arista EOS 4.35.4M.

Configurations alone are not able to completely secure a network. Due operational diligence including threat assessment and reaction are necessary to ensure device security. This guide provides recommendations that you are advised to implement, however, no document can be comprehensive for every unique environment.

The audit commands within broadly assume that operations are being performed at privilege level 15. The default prompt for this privilege level is **#** and as such all sample commands will have **#** as an additional indication that it is to be executed at privilege level 15.

To obtain the latest version of this guide, please visit <http://benchmarks.cisecurity.org>. If you have questions, comments, or have identified ways to improve this guide, please write us at benchmarkinfo@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Arista devices running Arista EOS.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit <https://workbench.cisecurity.org/>.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
<code>Stylized Monospace font</code>	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
<code>Monospace font</code>	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
<code><Monospace font in brackets></code>	Text set in angle brackets denote a variable requiring substitution for a real value.
<i>Italic font</i>	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like Notes , Warnings , or Cautions (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) "5.1 - Establish Secure Configurations" and (v8) "4.1 - Establish and Maintain a Secure Configuration Process" so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1**

Items in this profile are intended to:

- be practical and prudent;
- provide a clear security benefit; and
- not inhibit the utility of the technology beyond acceptable means.

- **Level 2**

This profile extends the "Level 1" profile. Items in this profile exhibit one or more of the following characteristics:

- are intended for environments or use cases where security is paramount
- acts as a defense in depth measure
- may negatively inhibit the utility or performance of the technology.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor

Graham Eames
Darren Stevenson
Edmund Roche-Kelly

Recommendations

1 EOS Services

The standard management protocols implemented in EOS leverage openly penetration tested services like sshd, rsyslogd, snmpd, ntpd and HTTPS with eAPI. These are based on open source packages that are up to date with all relevant security patches. Other services like routing protocols and MLAG are all disabled by default. The default control plane ACL entries filter connections to all available management interfaces.

1.1 Control Plane

The control plane is critical to all network operations as it is the component used to build all forwarding paths for the data plane. It is also instrumental with ongoing network management functions that keep the switches and links available for providing network services. Hence, any disruption to the control and management planes can result in mission critical network outages. A DoS attack targeting the control plane can be perpetrated either inadvertently or maliciously involving high rates of punted traffic resulting in excessive control plane CPU and memory utilization. To maintain network stability the switch must be able to securely handle specific control plane and management plane traffic that is destined to it. Control plane policing can be used to increase the security of Arista switches by protecting the control plane from unnecessary or malicious traffic. Filtering and rate limiting the traffic flow of control plane packets can be implemented to protect the switch against attacks. This allows the control plane to maintain packet forwarding and protocol states despite an attack.

1.1.1 Control Plane Traffic

Administrative traffic to and from the device is distinct from traffic through the device. In order to ensure the separation of management network traffic and normal production traffic it is recommended that the Management Interface is in a different management VRF. EOS services such as ssh and snmp support the designation of a vrf to use for their traffic.

This document will recommend the use of a management vrf for each service.

1.1.1.1 Ensure the Management VRF Exists (Manual)

Profile Applicability:

- Level 1

Description:

Ensure that the mgmt vrf exists and is assigned to the interface that connects to the management network for out of band access. The switch has a dedicated management interface that should be assigned to this vrf.

Rationale:

A Management VRF (Virtual Routing and Forwarding) is a dedicated, isolated routing instance on a network device used exclusively for out-of-band management traffic. It separates administrator access (like SSH, SNMP, and Syslog) from production data traffic.

Audit:

Verify vrf exists and is applied to management interface.

```
sho run section vrf instance mgmt
show running-config section interface Management
```

Remediation:

Create a vrf, assign it to the management interface and create a static route to the rest of the network. The vrf instance should have a meaningful name and description indicating its purpose.

```
vrf instance mgmt
    description Management VRF
!
interface Management1
    vrf mgmt

ip route vrf mgmt 0/0 {Gateway Address}
no ip routing vrf mgmt
```

Default Value:

The management interface is in the default vrf.

References:

1. https://www.arista.com/en/um-eos/eos-initial-switch-access#ethernet_management_port

1.1.2 Control Plane ACL (Manual)

Profile Applicability:

- Level 1

Description:

A default control plane ACL is provided and applied to the system control-plane. The default control-plane ACL is read-only, but you can create and assign a different ACL to the system control-plane if customization is needed. However, it is strongly recommended to use the default control-plane ACL as a template for any custom ACL that you may apply to ensure protocol and management operations function correctly.

Rationale:

The default control plane ACL filters all IP traffic inbound and outbound on any management interface. SSH, Telnet, NTP, SNMP, IP protocols, and logging/matching on management traffic are done by this ACL. The default control plane ACL permits the following protocols:

- Telnet
- SSH
- HTTP/S
- BootP
- SNMP
- ICMP
- MLAG
- IGMP
- OSPF
- BGP
- VRRP
- PIM
- AHP
- VNC

Impact:

While it is possible to create and apply a new/modified ACL to the system control-plane, modifying the control plane ACL may unexpectedly block services critical to the network operation. The default control plane allows all expected control plane protocols. A custom control plane acl may be overly broad, providing insufficient security, or too narrow to allow the network to function.

Audit:

Run the following command to check that either your custom ACL or the default ACL is applied

```
switch#show running-config all section system control-plane
system control-plane
    ip access-group custom-control-plane-acl in
    ip access-group default-control-plane-acl vrf MGMT in
switch#
```

The control plane ACL is referenced by the ip[v6] access-group <ACLNAME> in configuration.

If a customer access list is specified, verify this acl exists

```
switch#show run section access-list custom-control-plane-acl
```

Example output of a custom acl based on the default acl. This removed telnet and http access.

```
ip access-list custom-control-plane-acl
  counters per-entry
  10 permit icmp any any
  20 permit ip any any tracked
  30 permit udp any any eq bfd ttl eq 255
  40 permit udp any any eq bfd-echo ttl eq 254
  50 permit udp any any eq multihop-bfd micro-bfd sbfd
  60 permit udp any eq sbfd any eq sbfd-initiator
  70 permit ospf any any
  80 permit tcp any any eq ssh snmp bgp https msdp ldp netconf-ssh gnmi
  90 permit udp any any eq bootps bootpc ntp snmp ptp-event ptp-general rip
ldp
  100 permit tcp any any eq mlag ttl eq 255
  110 permit udp any any eq mlag ttl eq 255
  120 permit vrrp any any
  130 permit ahp any any
  140 permit pim any any
  150 permit igmp any any
  160 permit tcp any any range 5900 5910
  170 permit tcp any any range 50000 50100
  180 permit udp any any range 51000 51100
  190 permit tcp any any eq 3333
  200 permit tcp any any eq nat ttl eq 255
  210 permit tcp any eq bgp any
  220 permit rsvp any any
  230 permit tcp any any eq 9340
  240 permit tcp any any eq 9559
  250 permit udp any any eq 8503
  260 permit udp any any eq lsp-ping
  270 permit udp any eq lsp-ping any range 51900 51999
switch#
```

Remediation:

Apply a control plane ACL to the default vrf and all non default vrfs

```
switch(config)#system control-plane  
switch(config-system-cp)# ip access-group custom-control-plane-acl in  
switch(config-system-cp)# ip access-group custom-control-plane-acl vrf MGMT  
in
```

Default Value:

The default control plane is applied to all vrfs by default.

References:

1. <https://www.arista.com/en/um-eos/eos-data-transfer#xx1135265>

1.1.3 Control Plane Policy Map (Manual)

Profile Applicability:

- Level 1

Description:

The default configuration comes with a pre-configured policy map to ensure adequate rate limiting for most traffic types punted to the CPU.

Rationale:

Control plane policing can be used to increase the security of Arista switches by protecting the control plane from unnecessary or malicious traffic. It is recommended to implement control plane protection by classifying traffic types based on importance levels and configure filters to restrict and rate limit the traffic punted to the processor according to each class.

Audit:

Verify a policy map is applied to the control plane

```
switch#show running-config all section system control-plane
```

Expected output

```
system control-plane
  ip access-group default-control-plane-acl in
  ip access-group default-control-plane-acl vrf MGMT in
  ipv6 access-group default-control-plane-acl in
  ipv6 access-group default-control-plane-acl vrf MGMT in
  service-policy input copp-system-policy
switch#
```

Check the configuration of the service policy

```
#show policy-map type control-plane copp-system-policy
Service-policy input: copp-system-policy
  Number of units programmed: 1
  Hardware programming status: Successful

  Class-map: copp-system-bpdu (match-any)
    shape : 5000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-lacp (match-any)
    shape : 5000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-bfd (match-any)
    shape : 10000 pps
    bandwidth : 500 pps

  Class-map: copp-system-mlag (match-any)
    shape : 5000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-selfip-tc6to7 (match-any)
    shape : 5000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-selfip (match-any)
    shape : 5000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-tc6to7 (match-any)
    shape : 10000 pps
    bandwidth : 1000 pps

  Class-map: copp-system-vrrp (match-any)
    shape : 5000 pps
    bandwidth : 1000 pps

  Class-map: copp-system-lldp (match-any)
    shape : 10000 pps
    bandwidth : 1000 pps

  Class-map: copp-system-bgp (match-any)
    shape : 5000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-OspfIIsis (match-any)
    shape : 10000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-pim (match-any)
    shape : 10000 pps
    bandwidth : 5000 pps

  Class-map: copp-system-ptp (match-any)
    shape : 2500 pps
    bandwidth : 500 pps
```

```
Class-map: copp-system-ipmcsvd (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-igmp (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-ipmcmiss (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-glean (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-tc3to5 (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-arp (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-iplocking (match-any)
  shape : 2500 pps
  bandwidth : 500 pps

Class-map: copp-system-l3slowpath (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-l3ttl1 (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-cvx-heartbeat (match-any)
  shape : 5000 pps
  bandwidth : 1000 pps

Class-map: copp-system-cvx (match-any)
  shape : 10000 pps
  bandwidth : 5000 pps

Class-map: copp-system-dot1x-mba (match-any)
  shape : 2500 pps
  bandwidth : 250 pps

Class-map: copp-system-vxlan-vtep-learn (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-vxlan-encapsulation (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-mod (match-any)
```

```
    shape : 2500 pps
    bandwidth : 500 pps

Class-map: copp-system-default (match-any)
  shape : 8000 pps
  bandwidth : 1000 pps

Class-map: copp-system-l3destmiss (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-acllog (match-any)
  shape : 10000 pps
  bandwidth : 1000 pps

Class-map: copp-system-sflow (match-any)
  shape : 25024 pps
  bandwidth : 0 pps
```

Remediation:

If no policy is configured, enable the default policy

```
system control-plane
  service-policy input copp-system-policy
```

Default Value:

The predefined copp-system-policy is applied to the control plane by default.

References:

1. https://www.arista.com/en/um-eos/eos-traffic-management#xzx_fm3vHmHf

1.1.4 Network Time Protocol (Manual)

Profile Applicability:

- Level 1

Description:

EOS enables Network Time Protocol (ntp) on the switch by default, and time settings from any properly configured ntp server override the manual setting of the system clock.

ntp servers synchronize time settings of systems running an ntp client. The switch supports ntp versions 1 through 4, and uses version 4 by default.

Rationale:

Without synchronized time accurately correlating information between devices becomes difficult, if not impossible. If logs cannot be successfully compared between each of the routers, switches, and firewalls, it will be very difficult to determine the exact events that resulted in a network breach incident. NTP provides an efficient and scalable method for network elements to synchronize to an accurate time source. A trusted time source is important to ensure proper logging and correlation of events to a syslog server where forensic information can be gathered in addition to any information concerning potential threats. If possible it is recommended to configure more than one NTP server.

Audit:

```
hostname#show running-config section ntp
```

Remediation:

Configure one or more NTP servers. NTP should be provided via the management network.

```
switch(config)# ntp server vrf {management vrf} {Hostname|IPaddr} prefer  
switch(config)# ntp server vrf {management vrf} {Hostname|IPaddr}
```

Default Value:

NTP is enabled by default. No default NTP server is configured.

References:

1. <https://www.arista.com/en/um-eos/eos-system-clock-and-time-protocols#xx1106319>

1.1.5 NTP authentication (Manual)

Profile Applicability:

- Level 2

Description:

NTP authentication verifies that time updates come from a trusted server, preventing bad actors from spoofing time or altering your clock.

The NTP authentication model is the opposite of the typical client-server authentication model. NTP authentication enables an NTP client or peer to authenticate time received from their servers and peers. It's not used to authenticate NTP clients because NTP servers don't care about the authenticity of their clients as they never accept any time from them.

Rationale:

Authentication support allows the NTP client to verify that servers are in fact known and trusted and not intruders intending accidentally or intentionally to masquerade as a legitimate server.

Impact:

NTP authentication requires server side configuration with a matching key. Mismatches will prevent successful synchronization.

Audit:

```
switch#show run section ntp.*key
```

Example output

```
ntp authentication-key 1 sha1 7 120D0C1A1718150A29
ntp trusted-key 1
```

Remediation:

```
switch(config)#ntp authentication-key 1 sha1 timesync
switch(config)#ntp trusted-key 1
```

Default Value:

NTP is not authenticated by default

References:

1. <https://www.arista.com/en/um-eos/eos-system-clock-and-time-protocols#xx1106359>

1.1.6 DNS Configuration (Manual)

Profile Applicability:

- Level 1

Description:

It is recommended that a DNS server be defined for client resolver. This allows for the use of hostnames when configuring services such as ntp or syslog.

Rationale:

The susceptibility of IP addresses to spoofing translates to DNS host name and IP address mapping vulnerabilities. For example, suppose a source host wishes to establish a connection with a destination host and queries a DNS server for the IP address of the destination host name. If the response to this query is the IP address of a host operated by an attacker, the source host will establish a connection with the attacker's host, rather than the intended target. The user on the source host might then provide logon, authentication, and other sensitive data.

Audit:

Verify at least one name server is configured and the correct VRF is used for reachability to the name server

```
show running-config section name-server
```

Example output

```
ip name-server vrf MGMT 8.8.8.8
```

Remediation:

Configure at least one name server and a domain name. DNS services should be provided over the management network.

```
switch(config)# ip name-server {vrf [Management VRF]} {ip address}
```

Default Value:

There is no default name server.

References:

1. <https://www.arista.com/en/um-eos/eos-switch-administration-commands#xx1107749>

1.1.7 Logging (Manual)

Profile Applicability:

- Level 1

Description:

Logging is a critical part of network security. Maintaining an audit trail of system activity logs (syslog) can help identify configuration errors, understand past intrusions, troubleshoot service disruptions, and react to probes and scans of the network.

Rationale:

Syslog levels 0-6 are the levels required to collect the necessary information to help in the recovery process. It is recommended to log all messages except debugging and send all log data to a syslog server.

Audit:

Perform the following to determine if a syslog server is enabled. Verify one or more IP address(es) returns

```
show running-config section logging host
```

Remediation:

Configure a destination for syslog messages. Logging should be sent over the management vrf.

```
switch(config)# logging trap 6  
switch(config)# logging {vrf [management vrf]} host {ip address}
```

Default Value:

No logs are sent to any remote host.

References:

1. <https://www.arista.com/en/um-eos/eos-system-event-logging>

1.1.8 VLAN Management (Manual)

Profile Applicability:

- Level 1

Description:

VLAN 1 is a special VLAN that tags and handles most of the control plane traffic. VLAN 1 is enabled on all trunks and ports by default. Ensure VLAN1 is pruned from all trunk and access ports that do not require it.

Rationale:

Instability in one part of the network could affect VLAN 1, thereby influencing control-plane stability and therefore STP stability for all other VLANs.

Audit:

Vlan 1 should be suspended and not appear in the allowed list of trunk interfaces.

```
show running-config section ^vlan 1$
show running-config section switchport trunk allowed
```

Expected output

```
vlan 1
  state suspend
interface Ethernet48
  switchport trunk allowed vlan 2-4094
```

Remediation:

```
switch(config)# vlan 1
switch(config-vlan-1)# state suspend

switch(config)# interface Ethernet[X]
switch(config-if-EtX)# switchport trunk allowed vlan except 1
```

Default Value:

Vlan 1 is enabled by default and allowed on all trunk ports.

References:

1. https://www.arista.com/en/um-eos/eos-virtual-lans-vlans#xzx_c-6_lid0rZ

1.1.9 Syslog with TLS support (Manual)

Profile Applicability:

- Level 2

Description:

Syslog over TLS is a secure standard (RFC 5425) that encrypts log messages in transit using Transport Layer Security. It protects sensitive operational and security data from interception and tampering

Rationale:

Syslog messages may transit several hops to arrive at the intended collector. Some intermediary networks may not be trusted by the originator, relay, or receiver because the network is in a different security domain or at a different security level from the originator, relay, or collector. Another security concern is that the originator, relay, or receiver itself is in an insecure network.

By using TLS connections, syslog is better protected against attacks and information leakage.

Audit:

The logging host needs to be configured to use tls and the ssl profile must exist

```
show running-config section ssl.profile
```

Expected output

```
logging vrf MGMT host 10.1.1.1 protocol tls ssl-profile **syslog-profile**
management security
  ssl profile **syslog-profile**
    certificate clientCert key ClientKey
    trust certificate serverCA
  ``
```

Remediation:

1. Create an SSL profile

```
switch(config-mgmt-security)#ssl profile syslog-profile
switch(config-mgmt-sec-ssl-profile-syslog-profile)#certificate clientCert key
ClientKey
switch(config-mgmt-sec-ssl-profile-syslog-profile)#          trust certificate
serverCA
switch(config-mgmt-sec-ssl-profile-syslog-profile)#
```

2. Define syslog server

```
switch(config)#logging vrf MGMT host 10.1.1.1 protocol tls ssl-profile
syslog-profile
```

Default Value:

No default syslog server is defined. Syslog uses udp port 514 by default.

References:

1. https://www.arista.com/en/um-eos/eos-control-plane-security#xzx_ZxdQkzztCr
2. <https://www.arista.com/en/support/toi/eos-4-26-0f/14727-syslog-with-tls-support>

1.2 Enable AES-GCM Encryption of EOS Secrets (Manual)

Profile Applicability:

- Level 1

Description:

AES-GCM has been added as a method for storing symmetric secrets in EOS. This applies to secrets that must be used to remote systems, as found in NTP, TACACS+, and other places.

A new secret type “8a”, which stands for AES-256-GCM encryption type, has been introduced. Secrets can either be entered in type 0, plaintext, and automatically converted or entered directly as type 8a. Upon accepting a value which is encrypted using the new type “8a”, the CLI will validate the encrypted value to ensure that it is correctly encoded.

Rationale:

The default method of storing shared secrets is to obfuscate them in the running configuration. This obfuscation mean secrets can be easily reversed by copying the configuration out of the box. With AES-GCM, the configuration can be secured since the secrets cannot be easily reversed or decrypted by copying the configuration out of the box.

Audit:

```
switch#sho running-config section password encryption
```

Expected output

```
management security
password encryption reversible aes-256-gcm
```

Remediation:

```
switch#conf
switch(config)#management security
switch(config-mgmt-security)#password encryption reversible aes-256-gcm
```

Default Value:

By default, the encryption algorithm used in running-config is type-7 obfuscation.

References:

1. <https://www.arista.com/en/support/toi/eos-4-27-0f/14849-aes-gcm-encryption-of-eos-secret-configuration>

2 Device Access

2.1 Password Management

Once a management connection is made, passwords are the next line of defense on limiting access to a switch. The Arista switches use a series of passwords or secret keys to authenticate the user to the device. The standard response/reply is challenged when a user provides their password.

The user can be allowed access or denied access based upon the security configuration within the device. Leveraging mechanisms such as TACACS+ the user can also be granted access on a limited basis including limiting their ability to execute specific commands from the CLI. It is necessary to configure a locally administered password in the case where a TACACS+ server is unavailable and device access is needed. It is recommended that the enable secret password be used at all times to grant administrative access to the Arista switch.

The default switch configuration allows usernames that are not password protected to log in only from the console. The `aaa authentication policy local allow-nopassword-remote-login` command configures the switch to allow unprotected usernames to log in from any port. To reverse this setting to the default state, use `no aaa authentication policy local allow-nopassword-remote-login`.

Common security practices specify the following password complexity recommendations:

- Minimum password size: 8 characters
- Should not be based on a dictionary or known word such as username, server name, owner (e.g. Arista, Ubuntu, etc).
- Password should contain characters from at least 3 of the following 4 character sets:
 - uppercase characters 'A' – 'Z'
 - lowercase characters 'a' – 'z'
 - numbers '0' – '9'
 - other, e.g. !"£\$%^&*()@

2.1.1 Do not allow remote login without a password (Manual)

Profile Applicability:

- Level 1

Description:

The default switch configuration allows usernames that are not password-protected to log in only from the console. It is possible to configure the switch to allow unprotected usernames to log in from any port.

Rationale:

Allowing remote access to accounts without passwords is a severe security risk.

Audit:

Check if remote login without a password is enabled. By default this will return nothing.

```
#show running-config section allow-nopassword-remote-login
```

Output with feature enabled

```
#sho run section allow-nopassword-remote-login
aaa authentication policy local allow-nopassword-remote-login
```

Remediation:

Reset the feature to the default value

```
#default aaa authentication policy local allow-nopassword-remote-login
```

Default Value:

The default switch configuration does not allow usernames that are not password-protected to log in remotely.

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1348565>

2.1.2 Configure an enable password (Manual)

Profile Applicability:

- Level 1

Description:

The **enable** command controls access to Privileged EXEC and all configuration command modes. The **enable password** authorizes users to execute the enable command. When the enable password is set, the CLI displays a password prompt when a user attempts to enter Privileged EXEC mode.

Rationale:

It is recommended that the enable secret password be used at all times to grant administrative access to the Arista switch.

Audit:

Verify and enable password is set

```
#show running-config section enable password
```

Remediation:

Configure and enable password

```
(config)#enable password {password string}
```

Default Value:

No enable password is configured.

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1349127>

2.1.3 Create a password complexity policy (Manual)

Profile Applicability:

- Level 1

Description:

A password policy can be used to mandate password requirements

Rationale:

The policy enforces recommendations when creating local users.

Impact:

Passwords that don't meet the policy will be rejected

```
switch(config)#username joe secret arista
% Password doesn't meet minimum digits: at least 1 required.
% Password doesn't meet minimum special characters: at least 1 are required.
The special characters are (!"#$%&\'()*+,-./:;<=>?@[^]_`{|}~)
% Password doesn't meet minimum uppercase characters: at least 1 required.
% Password too short: at least 8 characters required.
switch(config)#
```

Audit:

Verify that a password policy is defined and applied

```
switch(config)#show run section password policy
management accounts
    password policy PasswordPolicy
management security
    password policy PasswordPolicy
        minimum digits 1
        minimum length 8
        minimum lower 1
        minimum special 1
        minimum upper 1
```

Remediation:

```
switch(config)#management security
switch(config-mgmt-security)#password policy PasswordPolicy
switch(config-pwd-policy-PasswordPolicy)#minimum length 8
switch(config-pwd-policy-PasswordPolicy)#minimum special 1
switch(config-pwd-policy-PasswordPolicy)#minimum upper 1
switch(config-pwd-policy-PasswordPolicy)#minimum lower 1
switch(config-pwd-policy-PasswordPolicy)#minimum digits 1
switch(config-pwd-policy-PasswordPolicy)#exit
switch(config-mgmt-security)#management accounts
switch(config-mgmt-accounts)#password policy PasswordPolicy
```

Default Value:

No default password policy is enforced

References:

1. https://www.arista.com/en/um-eos/eos-session-management-commands#management_accounts

2.1.4 Verify root login is disabled (Manual)

Profile Applicability:

- Level 1

Description:

EOS can be configured to allow logging in as root directly by using the `aaa root secret` config command. This should not be enabled. An authenticated, authorized user can obtain superuser access after logging in by accessing the bash shell if permitted.

Rationale:

Allowing remote root login bypasses the EOS cli and gives direct access to the bash shell.

Audit:

```
switch(config)#sho run section root
```

Expected output

```
no aaa root
```

Remediation:

Reset to default value

```
switch(config)#default aaa root
```

Default Value:

Root access is disabled.

2.3 User Role Management

Role based authorization is a method of restricting access to CLI command through the assignment of profiles, which are called roles to user accounts.

2.3.1 Roles (Manual)

Profile Applicability:

- Level 1

Description:

A role consists of rules that permit or deny access to a set of commands within specified command modes.

Rationale:

For local users a role limits the commands they can run to the appropriate set for their job.

Additional custom roles can be defined as needed or AAA services - such as TACACS+ - can be used to provide more granular access to the switch.

Impact:

Incorrect assignment of roles can prevent users performing required functions or allow users to perform actions they should not.

Audit:

```
show run all section ^role|username.*role
```

This shows two local users with different roles

```
username admin privilege 15 role network-admin secret sha512 XXXX
username operations privilege 15 role network-operator secret sha512 XXX
username user privilege 1 role network-admin nopassword
role network-admin
  10 permit command .*
role network-operator
  10 deny mode exec command configure|bash|python-shell|\\|
  20 permit mode exec command .*
```

Remediation:

Assign roles to local users with the username command

```
username name [PRIVILEGE_LEVEL] SECURITY [ROLE_USER]
```

SECURITY specifies the password assignment.

Default Value:

The default role is assigned to the following users:

- local or remote users assigned to a role that is not configured.
- local users to whom a role is not assigned.

When the default-role is not specified network-operator is assigned to qualified users as the default role. The network-operator role authorizes assigned users access to all CLI commands in EXEC and Privileged EXEC modes. However, it does not allow commands through which configuration changes can be made.

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1347683>

2.4 Console Access

Network elements with no password for administrative access via the console provide the opportunity for anyone with physical access to the device to make configuration changes enabling them to disrupt network operations resulting in a network outage.

2.4.1 Idle Timeout (Manual)

Profile Applicability:

- Level 1

Description:

Time out access to the console after a period of inactivity.

Rationale:

Inactive unattended console sessions provide the opportunity for anyone with physical access to the device to make configuration changes enabling them to disrupt network operations resulting in a network outage.

Audit:

Verify idle-timeout is configured

```
switch#show running-config section management console
management console
    idle-timeout 10
switch#
```

Remediation:

Configure idle timeout

```
switch#configure
switch(config)#management console
switch(config-mgmt-console)#idle-timeout ?
<0-86400> Idle session timeout in minutes

switch(config-mgmt-console)#idle-timeout 10
```

References:

1. <https://www.arista.com/en/um-eos/eos-session-management-commands#xx1129634>

2.4.2 Emergency Console Access (Manual)

Profile Applicability:

- Level 1

Description:

Authentication for administrative access to the device should be required at all times. A single account should be created on the device's local database for use in an emergency such as when the authentication server is down or connectivity between the device and the authentication server is not operable. The console or emergency account logon credentials should be stored in a secure location. SHA512 password hash should always be used and is the default in EOS.

Rationale:

Console access should be available even if authentication servers are down or unreachable, but should not be accessible without authentication or with simple passwords.

Audit:

Verify a local username is configured

```
switch#show running-config section username
username admin privilege 15 role network-admin secret sha512
$6$5TvDKp7afe5OBM2/$0BB5GMrdBbKox/wLhVaoLnUV9F2s6k8n9bs42StHnEi37owhb/BHpAIcw
lomotORDmIBoCvfMie5myiemsJkd.
```

Remediation:

```
switch(config-mgmt-defaults)#username admin privilege 15 role network-admin
secret ?
  0      Specify an UNENCRYPTED password will follow
  5      Specify an ENCRYPTED MD5 password will follow
  LINE   The UNENCRYPTED (cleartext) password
  sha512 Specifies an ENCRYPTED SHA512 password will follow
  *      Specify a password that cannot be used to login

switch(config-mgmt-defaults)#username admin privilege 15 role network-admin
secret <password>
switch(config)#
```

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1347335>

2.5 TACACS+/RADIUS

TACACS+ is an authentication protocol that can be used for authentication of management users against a remote AAA server. TACACS+ provides the ability to provide each individual a specified administrative account which eliminates the need for a single shared admin password. RADIUS is a similar protocol to TACACS+ and can be used to provide similar level functionality, however, RADIUS only encrypts the password in the packet which doesn't protect the username and accounting information. Please note that as TACACS+ encryption is considered weak and outdated by current standards an additional layer of security should be added for enhanced protection. SSH Tunnels detailed later provide this functionality. TACACS+ makes it possible to have different methods and servers for authentication, authorization, and accounting whereas RADIUS combines authentication and authorization. Lastly TACACS+ can restrict the commands specific users can run thus allowing for more granular control over network functions and services. Utilizing TACACS+ or RADIUS as a network control mechanism will assist in preventing unauthorized access and will enforce the organization's security policy. Levels of access should be defined based upon the needs of the administration and operations of the network. Authorization requires an individual account identifier that has been approved, assigned, and configured on an authentication server. Lack of authentication has inherent risks, which could include a security breach and catastrophic network outages.

2.5.1 Configure TACACS+/RADIUS server (Manual)

Profile Applicability:

- Level 1

Description:

The switch defines a TACACS+ server connection by its address and port. It is recommended to use two or more authentication servers for the purpose of granting administrative access.

Rationale:

At least one TACACS+ server must be configured.

Audit:

```
switch#show run section tacacs
```

Expected output

```
switch(config)#sho run section tacacs+
tacacs-server host 192.168.0.10 vrf MGMT key 8a XXXX
aaa group server tacacs+ TACPLUS
    server 192.168.0.10 vrf MGMT
aaa authentication login default group tacacs+ local
switch(config)#
```

Remediation:

This command configures the switch to communicate with the TACACS+ server assigned the host name TAC_1 using the encryption key rp31E2v.

```
switch(config)# tacacs-server host TAC-1 key rp31E2v
```

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1347425>

2.5.2 Server Groups (Manual)

Profile Applicability:

- Level 1

Description:

A server group is a collection of servers associated with a single group name. Subsequent authorization and authentication commands can access all servers in a group by invoking the group name. The switch supports TACACS+ and RADIUS server groups.

Rationale:

Server groups allow AAA commands to access multiple servers, providing redundancy and load sharing. Before they are added to a group, servers must have been previously configured with a radius-server host or tacacs-server host command.

Audit:

```
switch#show running-config section aaa group server
aaa group server tacacs+ TACPLUS
    server {ip address} vrf {management vrf}
    server {ip address} vrf {management vrf}
switch#
```

Remediation:

Configure a server group if required

```
aaa group server tacacs+ TACPLUS
    server {ip address}
    server {ip address}
```

Default Value:

No server groups are defined

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1347637>

2.5.3 Authentication, Authorization, and Accounting (Manual)

Profile Applicability:

- Level 1

Description:

The use of Authentication, Authorization, and Accounting (AAA) affords the best methods for controlling user access, authorization levels, and activity logging. By enabling AAA on the switches in conjunction with an authentication server such as TACACS+ or RADIUS the administrators can easily add or remove user accounts, add or remove command authorizations, and maintain a log of user activity.

Rationale:

The Authentication, Authorization, and Accounting (AAA) framework is essential to securing a network device. The AAA framework provides a mechanism to authenticate and limit specific actions being performed within a management session. AAA also allows for accounting and logging of any commands that are executed within a management session.

Impact:

Enabling AAA requires an authentication server available to accept connections and return results. Errors in configuration can lock users out of the device.

Audit:

```
switch#show running-config section aaa
aaa group server tacacs+ TACPLUS
    server {ip address} vrf mgmt
!
aaa authentication login default group TACPLUS local
aaa authentication enable default group TACPLUS local
aaa authorization exec default group TACPLUS local
aaa authorization commands all default group TACPLUS local
!
```

Remediation:

Configure AAA. Servers should be reachable via the management vrf.

```
switch(config)# aaa group server tacacs+ TACPLUS
switch(config-sg-tacacs+-TACPLUS)# server {ip address} vrf {management vrf}
switch(config-sg-tacacs+-TACPLUS)# server {ip address2} vrf {management vrf}
switch(config-sg-tacacs+-TACPLUS)# exit
switch(config)# aaa authentication default enable group TACACS+ local
switch(config)# aaa authentication login default group TACPLUS local
switch(config)# aaa authentication enable default group TACPLUS local
switch(config)# aaa authorization exec default group TACPLUS local
switch(config)# aaa authorization commands all default group TACPLUS local
```

Default Value:

AAA is disabled

References:

1. <https://www.arista.com/en/um-eos/eos-user-security#xx1348035>

2.6 SSH Access

SSH is an encrypted terminal protocol that can be used to establish a cli session to a network element. EOS only permits SSH login over the network by default.

2.6.1 Limit SSH Access Only To The Network Management Segment (Manual)

Profile Applicability:

- Level 1

Description:

The network element should only allow management connections for administrative access from hosts residing in the management network. It is recommended to review the configuration and verify management access to the device is allowed only from hosts within the management network.

Rationale:

Audit:

```
show running-config section management ssh
management ssh
    shutdown
    !
    vrf MGMT
    no shutdown
```

Remediation:

```
switch(config)#management ssh
switch(config-mgmt-ssh)#sho active
switch(config-mgmt-ssh)#vrf MGMT
switch(config-mgmt-ssh-vrf-MGMT)#no shutdown
switch(config-mgmt-ssh-vrf-MGMT)#exit
switch(config-mgmt-ssh)#shutdown
switch(config-mgmt-ssh)#end
```

Default Value:

SSH is allowed to all reachable IP addresses on the EOS switch.

References:

1. <https://www.arista.com/en/um-eos/eos-session-management-commands#xx1129753>

2.6.2 Set Idle Timeout for SSH to 10 Minutes or Less (Manual)

Profile Applicability:

- Level 1

Description:

Idle ssh sessions can be re-used by unauthorized users who have access to an unlocked workstation where a network admin has connected to network devices via ssh and has stepped away.

Rationale:

Audit:

```
show running-config | sec ssh
```

Remediation:

```
management ssh  
  idle-timeout 10
```

References:

1. <https://www.arista.com/en/um-eos/eos-session-management-commands#xx1129658>

2.6.3 Remove cryptographically weak algorithms (Manual)

Profile Applicability:

- Level 2

Description:

Outdated and insecure ciphers and algorithms should not be used.

Rationale:

An attacker can possibly break the encryption of transported data if weak ciphers and algorithms are used to access sensitive data.

Impact:

The algorithms used in an ssh session are negotiated between the client and the server. Restricting the list of accepted algorithms could prevent some clients connecting to the device.

Audit:

The allowed algorithms and methods are configured under **management ssh**

```
switch#show run all section management ssh
management ssh
  idle-timeout 0
  no login user match-list
  authentication protocol keyboard-interactive public-key
  server-port 22
  **cipher aes256-gcm@openssh.com aes128-gcm@openssh.com aes256-ctr aes192-
ctr aes128-ctr
  key-exchange curve25519-sha256@libssh.org ecdh-sha2-nistp521 ecdh-sha2-
nistp256 ecdh-sha2-nistp384 diffie-hellman-group14-sha1
  mac hmac-sha2-512-etm@openssh.com hmac-sha2-256-etm@openssh.com hmac-sha1-
etm@openssh.com hmac-sha2-512 hmac-sha2-256 hmac-sha1**
```

Remediation:

```
management ssh
  cipher aes128-ctr aes256-ctr
  key-exchange diffie-hellman-group14-sha256
  mac hmac-sha2-256
```

References:

1. <https://www.arista.com/jp/um-eos/eos-session-management-commands#xx1129753>

2.7 SNMP

SNMP (Simple Network Management Protocol) is an application-layer protocol used to monitor, manage, and potentially configure network elements. It enables centralized management and monitoring of network elements and their performance and device health across the network.

2.7.1 Limit SNMP Access To Management VRF (Manual)

Profile Applicability:

- Level 1

Description:

SNMP access should be restricted to the management vrf.

Rationale:

Detailed information about the network is sent across the network via SNMP. If this information is discovered by attackers it could be used to trace the network, show the network topology, and possibly gain access to network devices. Only allow SNMP access from addresses belonging to the management network.

Audit:

```
switch(config)# show running-config section snmp-server vrf
```

Expected output

```
no snmp-server vrf default
snmp-server vrf MGMT
```

Remediation:

```
snmp-server vrf {management VRF}
no snmp-server vrf default
```

Default Value:

snmp access (once communities or users are configured) will be enabled in the default vrf.

References:

1. <https://www.arista.com/en/um-eos/eos-snmp#xx1153372>

2.7.2 Ensure SNMP Community (Manual)

Profile Applicability:

- Level 1

Description:

Only allow SNMP read access and ensure that the default or well-known SNMP community strings public and private are not used. An ACL should be used to further restrict which remote hosts can query the switch.

Rationale:

Enabling write access to the device via SNMP provides a mechanism that can be exploited by an attacker to set configuration variables that can disrupt network operations.

Impact:

Changing SNMP communities requires matching configuration on remote devices that access the device via snmp.

Audit:

```
show running-config section snmp-server community
```

Remediation:

```
no snmp-server community public
no snmp-server community private
snmp-server community {community string} ro {snmp security acl}
```

Default Value:

SNMP is disabled by default

References:

1. <https://www.arista.com/en/um-eos/eos-snmp#xx1153379>

2.7.3 Use SNMPv3 Instead of Earlier Versions (Manual)

Profile Applicability:

- Level 1

Description:

The network element should use SNMP Version 3 for any SNMP agent configured on the device.

Rationale:

SNMPv2 only requires a community string to be specified, which the client needs to use in their requests to "authenticate".

SNMPv3 uses an actual security model called "User-based Security Model" (USM) codified in RFC3414 (originally in RFC2264 1998). USM supports authentication and encryption.

Impact:

Client requests will also need to use snmpv3 to poll the device.

Audit:

```
switch(config)#show run section snmp-server.*v3
```

This should show a configured user and matching group, with both authentication and priv enabled

```
snmp-server group snmpGroup v3 priv
snmp-server user snmpUser snmpGroup v3 localized {ENGINE ID} auth sha256
{auth string} priv aes256 {priv string}
```

Remediation:

```
snmp-server group group1 v3 priv
snmp-server user user1 group1 v3 auth sha256 12345 priv aes256 {password}
snmp-server host server1 version 3 priv user1
```

Default Value:

SNMPv3 is not enabled.

References:

1. <https://www.arista.com/en/um-eos/eos-snmp>

2.9 Login Banner

A legal banner is recommended on all external administrative interfaces. The purpose of a legal banner is to:

- Provide Legal Protection should evidence need to be used from a device.
- Act as a deterrent to potential intruders.
- This banner must be displayed prior to login.

There are certain items that must be included in a legal banner. These include:

- Statement that the device is for authorized users only.
- The device is for official use only.
- Users have no expectations of privacy.
- All access and use may (not will) be monitored and/or recorded.
- Monitoring and/or recording may be turned over to the appropriate authorities.
- Use of the system implies consent to the previously mentioned conditions.

The banner must not contain:

- Mention of the purpose, location or owner of the device or any other identification information.
- It should not say "Welcome" anywhere in the description.

Sample Login Banner:

```
*** WARNING ***  
This system is private and may be accessed only by authorized users for  
official purposes. The system owner reserves the right to monitor any and  
all activity taking place on this system and any attempts to connect to it.  
Individuals using this computer system are subject to having all of their  
activities monitored and recorded by system personnel. Use of this system  
evidences an express consent to such monitoring and agreement that if such  
monitoring reveals evidence of possible abuse or criminal activity, system  
personnel may provide the results of such monitoring to appropriate  
officials. Unauthorized users or users who exceed (or attempt to exceed),  
their authorized level of access are subject to prosecution under any local  
or international laws that apply as well as Company initiated proceedings.
```

2.9.1 Login Banner (Manual)

Profile Applicability:

- Level 1

Description:

The login banner precedes the login prompt. Use a login banner to warn against unauthorized network access attempts or other messages to users.

Rationale:

A legal banner is recommended on all external administrative interfaces. The purpose of a legal banner is to:

- Provide Legal Protection should evidence need to be used from a device.
- Act as a deterrent to potential intruders.
- This banner must be displayed prior to login.

Audit:

This command will display to login banner if it is configured.

```
show run section banner login
```

If a banner is configured this will be displayed.

```
banner login
```

The contents of the banner are up to the end user. There are certain items that must be included in a legal banner. These include:

- Statement that the device is for authorized users only.
- The device is for official use only.
- Users have no expectations of privacy.
- All access and use may (not will) be monitored and/or recorded.
- Monitoring and/or recording may be turned over to the appropriate authorities.
- Use of the system implies consent to the previously mentioned conditions.

The banner must not contain:

- Mention of the purpose, location or owner of the device or any other identification information.
- It should not say "Welcome" anywhere in the description.

Remediation:

Configure a banner. An example banner is provided as a reference.

```
switch(config)#banner login
Enter TEXT message. Type 'EOF' on its own line to end.
  *** WARNING ***
This system is private and may be accessed only by authorized users for
official purposes.
The system owner reserves the right to monitor any and all activity taking
place on this system and any attempts to connect to it.
Individuals using this computer system are subject to having all of their
activities monitored and recorded by system personnel.
Use of this system evidences an express consent to such monitoring and
agreement that if such monitoring reveals evidence of possible abuse or
criminal activity, system personnel may provide the results of such
monitoring to appropriate officials.
Unauthorized users or users who exceed (or attempt to exceed), their
authorized level of access are subject to prosecution under any local or
international laws that apply as well as Company initiated proceedings.
EOF
switch(config)#
```

Default Value:

By default no banner is presented.

References:

1. <https://www.arista.com/en/um-eos/eos-switch-administration-commands#xx1107345>

2.8 Telnet access (Manual)

Profile Applicability:

- Level 1

Description:

Telnet transmits credentials and data in cleartext. It is disabled by default and should not be enabled.

Rationale:

Telnet is an obsolete protocol vulnerable to eavesdropping.

Audit:

Verify telnet is shutdown

```
switch#show run all section management telnet
management telnet
  shutdown
  idle-timeout 0
  no login user match-list
  session-limit 20
  session-limit per-host 20
switch#
```

Remediation:

Disable telnet

```
switch#conf
switch(config)#management telnet
switch(config-mgmt-telnet)#shutdown
switch(config-mgmt-telnet)#end
switch#
```

Default Value:

Telnet access is disabled.

References:

1. <https://www.arista.com/zh/um-eos/eos-session-management-commands#xx1129785>

2.9 API access using https (Manual)

Profile Applicability:

- Level 2

Description:

The Arista Command eAPI is a simple and complete API that allows you to configure and monitor your Arista switches. Once the API is enabled, the switch accepts HTTPS requests containing a list of industry standard CLI commands, and responds with machine-readable output and errors serialized in JSON (served over HTTP or HTTPS). HTTP can be enabled but should be left disabled.

Rationale:

EOS API provides structured output more suitable for programmatic parsing than cli scraping. If the API is enabled, it should only use https, not http.

Audit:

```
switch#show run section api http-commands
```

This output shows the api is enabled in the default vrf and both http and https are enabled.

```
management api http-commands
  protocol http
  no shutdown
  !
  vrf MGMT
    no shutdown
```

Remediation:

```
switch(config)#management api http-commands
switch(config-mgmt-api-http-cmds)#no shutdown
switch(config-mgmt-api-http-cmds)#default protocol http
switch(config-mgmt-api-http-cmds)#vrf MGMT
switch(config-mgmt-api-http-cmds-vrf-MGMT)#no shutdown
switch(config-mgmt-api-http-cmds-vrf-MGMT)#
```

Default Value:

API is disabled by default

References:

1. <https://arista.my.site.com/AristaCommunity/s/article/arista-eapi-101>

3 Routing Protocols

3.1 IGP Authentication

Securing the routing protocols is an essential task to minimize the ability for a rogue device to send incorrect information and potentially disrupt the forwarding plane. Using fictitious information could also allow an attacker the ability to send information to an unsecure location where the data could be captured and analyzed. It is recommended to authenticate all IGP Peers.

3.1.1 OSPF Interface Authentication (Manual)

Profile Applicability:

- Level 2

Description:

OSPF authentication secures routing updates by verifying the identity of neighboring routers, preventing malicious devices from injecting false routing information.

The OSPFv2 Secure Hash Algorithms (SHA) Authentication support as defined in RFC 5709 supports the configuration of SHA1, SHA256, SHA384 and SHA512 Message-Digest authentication as an alternative to the MD5 Message-Digest authentication.

Rationale:

Because a routing protocol contains information that need not be kept secret, privacy is not a requirement. However, authentication of the messages within the protocol is of interest in order to reduce the risk of an adversary compromising the routing system by deliberately injecting false information into the routing system.

SHA256 or higher should be used due to concerns about the overall strength of the MD5 and SHA1 algorithm.

Audit:

Verify OSPF authentication is enabled.

```
show running-config section ip ospf authentication
```

Sample output

```
#show running-config section ip ospf authentication
interface Vlan10
  ip ospf authentication message-digest
  ip ospf authentication message-digest-key 10 sha256 7 xxxxxxxx
```

Remediation:

Configure OSPF authentication on interfaces connected to OSPF neighbors

```
interface {interface-name}
  ip ospf authentication message-digest
  ip ospf authentication message-digest-key {number} sha256 {key text}
```

Default Value:

OSPF authentication is not enabled

References:

1. <https://www.arista.com/en/um-eos/eos-open-shortest-path-first-version-2#xx1153125>

3.1.2 ISIS Interface and Instance Authentication (Manual)

Profile Applicability:

- Level 2

Description:

Enable authentication of ISIS hellos on interfaces and LSPs, CSNPs, and PSNPs for the protocol instance.

Rationale:

IS-IS authentication secures routing adjacencies and LSDB updates by validating the source of protocol packets.

Audit:

To verify authentication is enabled for ISIS hellos, look for isis authentication configuration on interfaces connected to ISIS neighbors.

```
show running-config section isis authentication
```

Sample output

```
#show running-config section isis authentication
interface Vlan100
  isis authentication mode md5
  isis authentication key 7 Xe8ywYMTkcpNrvJCQ+qXOg==
```

To verify authentication for the IS-IS instance causing LSPs, CSNPs, and PSNPs to be authenticated is enable:

```
switch#show running-config section ^router isis | section authentication
router isis 1
  authentication mode md5
  authentication key 7 /Dtzvo8XRzKTptlDkyhexQ==
```

Remediation:

```
interface Ethernet {X}
  isis authentication mode md5
  isis authentication key {key}

router isis {protocol instance}
  authentication mode md5
  authentication key {key}
```

References:

1. <https://www.arista.com/en/um-eos/eos-is-is#xx1232963>

3.2 BGP Authentication

Securing an IGP is important for internal threats to a network. When utilizing BGP the threat profile becomes much larger as routes external to the data center will be updating routing information in the devices. Much like with the IGP an attacker could redirect traffic to an insecure location where traffic could be analyzed and confidential information extracted. In the case of BGP a peer AS can send erroneous prefix information and as a result could allow packets to be sent to an insecure network. It is recommended that peer authentication be used for all peers. A password or key should be defined for each BGP neighbor regardless of the peer's autonomous system.

3.2.1 BGP Authentication (Manual)

Profile Applicability:

- Level 2

Description:

The neighbor password command enables authentication on a TCP connection with a BGP peer

Rationale:

When utilizing BGP the threat profile becomes much larger as routes external to the data center will be updating routing information in the devices. Much like with the IGP an attacker could redirect traffic to an insecure location where traffic could be analyzed and confidential information extracted. In the case of BGP a peer AS can send erroneous prefix information and as a result could allow packets to be sent to an insecure network. It is recommended that peer authentication be used for all peers. A password or key should be defined for each BGP neighbor regardless of the peer's autonomous system.

Audit:

Verify each bgp neighbor has a password

```
show running-config section neighbor.*password
router bgp 65013
  neighbor 1.1.1.1 password 8a XXXXX
```

Remediation:

Configure passwords for each neighbor as appropriate

```
router bgp
  neighbor {IP address} password
```

Default Value:

No password is configured.

References:

1. <https://www.arista.com/en/um-eos/eos-border-gateway-protocol-bgp#xx1117278>

3.2.2 BGP TCP Authentication Option (TCP-AO) (Manual)

Profile Applicability:

- Level 2

Description:

BGP TCP Authentication Option (TCP-AO) (RFC 5925) support adds a new option for BGP message and TCP segments authentication using superior hashing algorithms such as HMACs and CMACs as an improvement over TCP MD5, with stronger hashing algorithms providing higher security and protection against replays attacks. It also provides better key management by coordinating between the endpoints to rotate to a new secret key or the master key tuple (MKT) without resetting the TCP connection.

Rationale:

EOS supports BGP message authentication via the TCP MD5 Signature (TCP MD5) option (RFC 2385) to protect the BGP sessions from spoofed TCP segments. However, research has shown many concerns that the TCP MD5 algorithm is cryptographically ineffective with a just simple keyed hash for authentication.

Audit:

TCP-AO requires a shared secret profile with a valid lifetime and a per-neighbor configuration to use the shared secret.

```
#show running-config section shared-secret
management security
  session shared-secret profile TCPAO
    secret 1 7 $1c$G8BQN0ezkiJOX2cuAYpsEA== receive-lifetime 2026-01-01
00:00:00 2026-12-31 23:59:59 transmit-lifetime 2026-01-01 00:00:00 2026-12-31
23:59:59
router bgp 65013
  neighbor {IP Address} password shared-secret profile TCPAO algorithm hmac-
sha-256
```

Remediation:

Enable TCP-AO using the secret keys in Shared Secret Profile NAME with a specified algorithm:

```
router bgp {ASN}
  neighbor NEIGHBOR_ID password shared-secret profile NAME algorithm ALGORITHM
```

Default Value:

No authentication is used for neighbors.

References:

1. <https://www.arista.com/en/support/toi/eos-4-28-2f/16087-bgp-tcp-authentication-option-tcp-ao>

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	EOS Services		
1.1	Control Plane		
1.1.1	Control Plane Traffic		
1.1.1.1	Ensure the Management VRF Exists (Manual)	☐	☐
1.1.2	Control Plane ACL (Manual)	☐	☐
1.1.3	Control Plane Policy Map (Manual)	☐	☐
1.1.4	Network Time Protocol (Manual)	☐	☐
1.1.5	NTP authentication (Manual)	☐	☐
1.1.6	DNS Configuration (Manual)	☐	☐
1.1.7	Logging (Manual)	☐	☐
1.1.8	VLAN Management (Manual)	☐	☐
1.1.9	Syslog with TLS support (Manual)	☐	☐
1.2	Enable AES-GCM Encryption of EOS Secrets (Manual)	☐	☐
2	Device Access		
2.1	Password Management		
2.1.1	Do not allow remote login without a password (Manual)	☐	☐
2.1.2	Configure an enable password (Manual)	☐	☐
2.1.3	Create a password complexity policy (Manual)	☐	☐
2.1.4	Verify root login is disabled (Manual)	☐	☐
2.3	User Role Management		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.3.1	Roles (Manual)	☐	☐
2.4	Console Access		
2.4.1	Idle Timeout (Manual)	☐	☐
2.4.2	Emergency Console Access (Manual)	☐	☐
2.5	TACACS+/RADIUS		
2.5.1	Configure TACACS+/RADIUS server (Manual)	☐	☐
2.5.2	Server Groups (Manual)	☐	☐
2.5.3	Authentication, Authorization, and Accounting (Manual)	☐	☐
2.6	SSH Access		
2.6.1	Limit SSH Access Only To The Network Management Segment (Manual)	☐	☐
2.6.2	Set Idle Timeout for SSH to 10 Minutes or Less (Manual)	☐	☐
2.6.3	Remove cryptographically weak algorithms (Manual)	☐	☐
2.7	SNMP		
2.7.1	Limit SNMP Access To Management VRF (Manual)	☐	☐
2.7.2	Ensure SNMP Community (Manual)	☐	☐
2.7.3	Use SNMPv3 Instead of Earlier Versions (Manual)	☐	☐
2.9	Login Banner		
2.9.1	Login Banner (Manual)	☐	☐
2.8	Telnet access (Manual)	☐	☐
2.9	API access using https (Manual)	☐	☐
3	Routing Protocols		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.1	IGP Authentication		
3.1.1	OSPF Interface Authentication (Manual)	☐	☐
3.1.2	ISIS Interface and Instance Authentication (Manual)	☐	☐
3.2	BGP Authentication		
3.2.1	BGP Authentication (Manual)	☐	☐
3.2.2	BGP TCP Authentication Option (TCP-AO) (Manual)	☐	☐

Appendix: Change History

Date	Version	Changes for this version